Responsible AI, Privacy, Security, Human Oversight

• Grounding: prompt confines generation to supplied retrieved text and mandates exact chunk IDs.

• Abstention: explicit insufficient-evidence phrase for information absent from evidence; validate real behavior before claiming reliable refusal.

• Traceability: source document, page, section, chunk ID and evidence snippet are shown to users.

• Verifier limitations: syntactic citation-ID validity does not prove every generated claim is supported or logically implied by the source.

• Prompt injection: source text is lower-trust and delimiters are sanitized, but this is not a complete defense.

• Data privacy: only use authorized HLDs; a remote Gemini call may send extracted proprietary content to an external provider. Do not commit private OEM data or .env.

• Key handling: store credentials in private environment files or secret vaults; avoid logs and screenshots with keys.

• Human review: an automotive engineer must verify architecture/safety claims; no ASIL compliance or production safety assurance is certified.

• Reporting integrity: distinguish test expectations, MockLLM outputs and verified real Gemini results. Disclose failures; never fabricate metrics.

Potential future controls include tenant isolation, access permissions, retention policies and claim-level evidence verification.